

# ENCUESTA INTEGRAL DE EVALUACIÓN DE CIBERSEGURIDAD ORGANIZACIONAL

## Modelo Detallado con Escalas de Madurez - 2026

**Versión:** 1.0 | **Fecha:** Enero 2026

**Destinatarios:** Responsables de ciberseguridad, directores ejecutivos, gestores de TI, líderes de seguridad

**Duración Estimada:** 45-60 minutos | **Formato:** Autoadministrable con validación

## INSTRUCCIONES PRELIMINARES

Esta encuesta propone un viaje sardónico pero constructivo por los rincones a menudo descuidados de la ciberseguridad organizacional. No se trata de un test de aprobado/suspenso, sino de un espejo estratégico donde reconocerse (con una sonrisa irónica) es el primer paso hacia la transformación defensiva genuina.

Cada sección emplea una **escala de madurez de 6 niveles** (Inexistente → Optimizado), reconociendo que la perfección es enemiga del progreso, y que el viaje importa más que el destino—aunque un destino seguro no está nada mal.

## MÓDULO 1: GOBERNANZA Y LIDERAZGO EN CIBERSEGURIDAD

### Sección 1A: Estructura Organizacional y Rol del CISO

**Pregunta 1.1:** ¿Cuál es el estado actual de la función de ciberseguridad en vuestra organización?

- Nivel 0 - Inexistente: No existe rol de ciberseguridad formalizado; la seguridad es responsabilidad ocasional de TI
- Nivel 1 - Inicial: Existe un responsable ad-hoc; reporta a TI o infraestructura; sin presupuesto dedicado
- Nivel 2 - Repetible: CISO/Jefe Seguridad existe; reporta a CTO o VP Operaciones; presupuesto anual definido
- Nivel 3 - Definido: CISO con autoridad clara; reporta a CEO/COO; participación en junta directiva; presupuesto multianual
- Nivel 4 - Cuantitativamente Gestionado: CISO con power dotado; reporta a CEO; presupuesto estratégico; métricas de valor agregado documentadas
- Nivel 5 - Optimizado: CISO como ejecutivo C-level; autoridad transversal; presupuesto integrado en capex/opex corporativo; alineación con objetivos negocio

**Pregunta 1.2:** ¿Con qué frecuencia se revisa la estrategia de ciberseguridad con liderazgo ejecutivo?

- Nivel 0: Nunca (¿ciberseguridad estrategia? Suena a ciencia ficción)
- Nivel 1: Anualmente o cuando hay incidente
- Nivel 2: Semestralmente en reuniones formales
- Nivel 3: Trimestralmente con KPIs documentados
- Nivel 4: Mensualmente con business alignment reviews
- Nivel 5: Continuamente; integrado en governance juntas directivas

**Pregunta 1.3:** ¿Existe una política de ciberseguridad documentada y comunicada a toda la organización?

- Nivel 0: No existe documentación formal
- Nivel 1: Existe borrador; circulación limitada a TI
- Nivel 2: Política publicada; disponible en intranet; requiere acknowledgment anual
- Nivel 3: Política integrada en employee handbook; training obligatorio; revisiones anuales
- Nivel 4: Políticas versión-controladas; integración procesos RRHH; métricas cumplimiento por departamento
- Nivel 5: Políticas dinámicas; auto-actualizadas conforme threats emergen; role-based customization

### Sección 1B: Alineación Estratégica y Presupuestación

**Pregunta 1.4:** ¿Cómo se alinea el presupuesto de ciberseguridad con los objetivos comerciales?

- Nivel 0: Sin alineación; presupuesto es mitigación reactiva
- Nivel 1: Alineación vaga; presupuesto responde a incidentes
- Nivel 2: Presupuesto anual; ligado a compliance requerimientos
- Nivel 3: Presupuesto táctico-estratégico; mapeo a activos críticos y procesos clave
- Nivel 4: Presupuesto model-based; ROI cuantificado; integración con risk tolerance del negocio
- Nivel 5: Presupuesto dinámico; asignación real-time basada en emerging threats; tied to business resilience outcomes

**Pregunta 1.5:** ¿Cuál es la inversión anual en ciberseguridad como % del presupuesto IT?

- Nivel 0: <1% (¿todavía existimos porque nadie nos atacó?)
- Nivel 1: 1-3% (respuesta reflexiva a breaches)
- Nivel 2: 3-5% (compliance-driven investment)
- Nivel 3: 5-8% (risk-based allocation)
- Nivel 4: 8-12% (strategic capability building)
- Nivel 5: >12% + discretionary allocation (integrated security excellence)

## MÓDULO 2: GESTIÓN DE VULNERABILIDADES Y PRUEBAS DE PENETRACIÓN

### Sección 2A: Programa de Gestión de Vulnerabilidades

**Pregunta 2.1:** ¿Cuál es el estado de madurez del programa de gestión de vulnerabilidades?

- Nivel 0: No existe scanning sistematizado; vulnerabilidades descubiertas ad-hoc
- Nivel 1: Scanning anual o semiestral; sin priorización formal
- Nivel 2: Scanning regular (trimestral); clasificación por CVSS; SLAs básicos remediation
- Nivel 3: Scanning continuo; correlación asset inventory; risk-based prioritization; SLAs por severidad
- Nivel 4: Continuous assessment; integración threat intel; automated workflows remediation; MTTR métricas
- Nivel 5: Continuous/real-time; predictive analysis; automated exploitation validation; closed-loop feedback

**Pregunta 2.2:** ¿Qué porcentaje de vulnerabilidades críticas/altas se remedian dentro de SLA establecidos?

- Nivel 0: <30% (remediation es sugerencia, no mandato)
- Nivel 1: 30-50% (esfuerzo inconsistente)
- Nivel 2: 50-70% (proceso existe; cumplimiento variable)
- Nivel 3: 70-85% (disciplina establecida; excepciones documentadas)
- Nivel 4: 85-95% (automatización contribuye)
- Nivel 5: >95% (integración workflow; non-remediation escalation automática)

**Pregunta 2.3:** ¿Existe integración entre scanning de vulnerabilidades y threat intelligence?

- Nivel 0: No; scanning y threat intel operan en silos completos
- Nivel 1: Integración manual ocasional
- Nivel 2: Integración parcial; correlación exploits conocidos con vulnerabilidades
- Nivel 3: Integración formal; threat intel enriquece priorización
- Nivel 4: Integración automatizada; alertas contextualizadas; scoring dinámico
- Nivel 5: Integración tight; predictive prioritization; automated response workflows

## Sección 2B: Pruebas de Penetración (Pen Testing)

**Pregunta 2.4:** ¿Con qué frecuencia se ejecutan pruebas de penetración?

- Nivel 0: Nunca (¿por qué buscar problemas que desconocemos?)
- Nivel 1: Ad-hoc o upon compliance requirement (anual máximo)
- Nivel 2: Anual comprehensive + biannual targeted
- Nivel 3: Trimestral o cuatrimestral; rotación de activos críticos
- Nivel 4: Continuous red teaming; monthly assessments; ongoing emulation
- Nivel 5: Continuous purple teaming; real-time adversary simulation; integrated tabletop exercises

**Pregunta 2.5:** ¿Qué metodología se emplea en las pruebas de penetración?

- Nivel 0: No estructurada o inexistente
- Nivel 1: Ad-hoc; basada en herramientas genéricas (e.g., Metasploit sin contexto)
- Nivel 2: Basada framework (OWASP, NIST); scope definido; reportes estándar
- Nivel 3: Customized framework; threat modeling inform testing; exploitation chaining documentada
- Nivel 4: Advanced frameworks (MITRE ATT&CK); tactic-based simulation; business impact assessment
- Nivel 5: Continuous AI-augmented simulation; predictive attack path generation; integrated with incident response playbooks

**Pregunta 2.6:** ¿Cuál es la media de tiempo desde hallazgo de vulnerabilidad crítica hasta remediation completa?

- Nivel 0: >180 días (generación espontánea de seguridad eventual)
- Nivel 1: 90-180 días (urgencia variable)
- Nivel 2: 30-90 días (proceso definido pero lento)
- Nivel 3: 15-30 días (SLA operativo)
- Nivel 4: 5-15 días (automatización contribuye)
- Nivel 5: <5 días (remediation nearly immediate; exceptions rare)

**Pregunta 2.7:** ¿Se realiza retest/validación post-remediation?

- Nivel 0: No; se asume que el fix funcionó
- Nivel 1: Sí, pero inconsistentemente
- Nivel 2: Sí; retest obligatorio para críticos/altos
- Nivel 3: Sí; retest automático post-remediation; documentado
- Nivel 4: Sí; integrado en workflow; validación de múltiples vectores
- Nivel 5: Sí; continuous revalidation; predictive retest basada en patterns históricos

## Sección 2C: Cobertura y Scope de Testing

**Pregunta 2.8:** ¿Qué porcentaje de aplicaciones críticas/datos sensibles se evalúan anualmente?

- Nivel 0: <20% (esperanza de que nadie descubra lo que no testamos)
- Nivel 1: 20-40% (selective testing)
- Nivel 2: 40-60% (meaningful but incomplete)
- Nivel 3: 60-80% (substantial coverage)
- Nivel 4: 80-95% (near-complete; exclusiones documentadas)
- Nivel 5: >95% + continuous incremental testing (coverage near 100%)

**Pregunta 2.9:** ¿Se incluyen en el scope de testing: (Seleccionar todos que apliquen)\*\*

- ☐ Aplicaciones internas únicamente
- ☐ Infraestructura on-premise
- ☐ APIs y microservicios
- ☐ Integraciones terceros (supply chain)
- ☐ Cloud environments (SaaS, PaaS, IaaS)
- ☐ Dispositivos IoT / OT críticos
- ☐ Cadena de suministro software (SBOM validation)
- ☐ Social engineering / phishing simulations

#### **Interpretación Madurez (# items seleccionados):**

- Nivel 0: 0-1
- Nivel 1: 2-3
- Nivel 2: 4-5
- Nivel 3: 6-7
- Nivel 4-5: 8 items

## **MÓDULO 3: GESTIÓN DE INFORMACIÓN Y EVENTOS DE SEGURIDAD (SIEM)**

### **Sección 3A: Presencia y Arquitectura SIEM**

**Pregunta 3.1:** ¿Existe una solución SIEM (o equivalente) desplegada?

- Nivel 0: No; logs dispersos o no recopilados
- Nivel 1: Sí; desplegada recientemente; configuración inicial
- Nivel 2: Sí; estable; cobertura de infraestructura core
- Nivel 3: Sí; integrada múltiples fuentes; tuning proactivo
- Nivel 4: Sí; arquitectura distribuida; integración threat intel; automated playbooks
- Nivel 5: Sí; cloud-native architecture; AI-driven correlation; predictive alerting

**Pregunta 3.2:** ¿Qué fuentes de logs se integran en el SIEM? (Seleccionar todos que apliquen)\*\*

- ☐ Firewalls / Network segmentation
- ☐ Servidores Windows / Linux
- ☐ Aplicaciones empresariales (ERP, CRM, etc.)
- ☐ Bases de datos
- ☐ Endpoints / EDR agents
- ☐ Cloud services (AWS, Azure, GCP logs)
- ☐ Servicios de identidad (Active Directory, SSO logs)
- ☐ Dispositivos de seguridad adicionales (WAF, IPS)
- ☐ IoT / OT devices
- ☐ Aplicaciones custom desarrolladas

#### **Interpretación Madurez (# fuentes):**

- Nivel 0: 0-1
- Nivel 1: 2-3

- Nivel 2: 4-5
- Nivel 3: 6-7
- Nivel 4: 8-9
- Nivel 5: 10 (todas)

**Pregunta 3.3:** ¿Cuál es la capacidad de retención de logs en el SIEM?

- Nivel 0: <30 días o unknown (corta amnesia digital)
- Nivel 1: 30-90 días
- Nivel 2: 90 días a 6 meses
- Nivel 3: 6 a 12 meses
- Nivel 4: 1-2 años
- Nivel 5: >2 años (archived with indexed searchability)

### Sección 3B: Capacidades de Detección y Alerting

**Pregunta 3.4:** ¿Qué tipo de alertas/detecciones se implementan?

- Nivel 0: Sin alertas formales; discovery reactivo
- Nivel 1: Alertas basadas reglas simples (e.g., failed logins >5)
- Nivel 2: Reglas correlation; signature-based threats
- Nivel 3: Comportamiento-basado (UEBA); baselines dinámicos
- Nivel 4: ML-based anomaly detection; integración threat intel; playbook execution
- Nivel 5: Predictive AI detection; behavioral profiling; real-time response automation

**Pregunta 3.5:** ¿Cuál es el volumen aproximado de eventos procesados diariamente?

- Nivel 0: <10K eventos/día (actividad mínima)
- Nivel 1: 10K-100K eventos/día
- Nivel 2: 100K-1M eventos/día
- Nivel 3: 1M-10M eventos/día
- Nivel 4: 10M-100M eventos/día
- Nivel 5: >100M eventos/día (enterprise-scale)

**Pregunta 3.6:** ¿Cuál es la tasa de false positives estimada?

- Nivel 0: Unknown (nunca se midió)
- Nivel 1: >50% (más ruido que señal)
- Nivel 2: 30-50% (ajuste de reglas en progreso)
- Nivel 3: 10-30% (tuning activo)
- Nivel 4: 5-10% (automatización reduce FPs)
- Nivel 5: <5% (integración context enriquecido)

### Sección 3C: Integración y Orquestación

**Pregunta 3.7:** ¿Está el SIEM integrado con herramientas de respuesta a incidentes (SOAR)?

- Nivel 0: No; sin automatización
- Nivel 1: Integración manual ocasional
- Nivel 2: Integración parcial; playbooks básicos
- Nivel 3: Integración formal; playbooks documentados; escalation automática
- Nivel 4: Orquestación completa; workflow multi-herramienta; feedback loops
- Nivel 5: Orchestration inteligente; self-learning playbooks; autonomous response

**Pregunta 3.8:** ¿Se ejecutan búsquedas proactivas ("threat hunts") usando el SIEM?

- Nivel 0: No (las amenazas vienen a encontrarnos)
- Nivel 1: Ad-hoc; no estructuradas
- Nivel 2: Mensuales; basadas threat intelligence compartida
- Nivel 3: Semanales; hypothesis-driven; documentadas
- Nivel 4: Continuamente; integración threat intel; multiple hypothesis tracks
- Nivel 5: Continuous AI-augmented hunting; predictive threat track generation

### Sección 3D: Compliance y Reportería

**Pregunta 3.9:** ¿Qué marcos regulatorios se cubren mediante reportería SIEM? (Seleccionar todos)\*\*

- ☐ GDPR (EU data protection)
- ☐ NIS2 / NIS (Network security)
- ☐ HIPAA (Healthcare)
- ☐ PCI-DSS (Payment card)
- ☐ ISO 27001 / ISO 27002
- ☐ SOC 2 Type II
- ☐ Regulaciones sector-específicas (Finanzas, Utilities)
- ☐ Auditoría interna / requisitos stakeholders
- ☐ Ninguno formal

**Pregunta 3.10:** ¿Con qué frecuencia se generan reportes de compliance/incident?

- Nivel 0: Nunca (compliance es palabra extraña)
- Nivel 1: Ad-hoc / post-incident
- Nivel 2: Anuales o trimestrales
- Nivel 3: Mensuales
- Nivel 4: Semanales + executive dashboards
- Nivel 5: Real-time automated dashboards + scheduled distributions

## MÓDULO 4: GESTIÓN DE ACCESO Y IDENTIDAD

### Sección 4A: Infraestructura de Identidad

**Pregunta 4.1:** ¿Cuál es el estado actual del sistema de gestión de identidades?

- Nivel 0: Gestión descentralizada o inexistente
- Nivel 1: Directorio centralizado (e.g., AD) para on-premise; cloud identity separado
- Nivel 2: AD/LDAP centralizado; sincronización cloud parcial
- Nivel 3: Identidad federada (SAML/OIDC); SSO implementado
- Nivel 4: Identity fabric; contexto-aware access; integración threat intel
- Nivel 5: Zero-trust identity; continuous verification; behavioral adaptation

**Pregunta 4.2:** ¿Se implementa autenticación multifactor (MFA) para: (Seleccionar todos)\*\*

- ☐ Acceso VPN/Remoto
- ☐ Aplicaciones críticas
- ☐ Acceso administrativo
- ☐ Acceso a datos sensibles
- ☐ Cloud services (Office 365, Salesforce, etc.)
- ☐ Todos los usuarios / todos los accesos

**Interpretación (# de áreas):**

- Nivel 0: No implementado
- Nivel 1: 1 área
- Nivel 2: 2-3 áreas
- Nivel 3: 4-5 áreas
- Nivel 4: 6 áreas parcialmente
- Nivel 5: 6 áreas universalmente

**Pregunta 4.3:** ¿Existe un programa de Privileged Access Management (PAM)?

- Nivel 0: No; acceso administrativo sin restricciones formales
- Nivel 1: Sí; password vault basic; sin auditoría
- Nivel 2: Sí; vault centralizado; auditoría básica
- Nivel 3: Sí; integración AD; sesión recording; workflow approval
- Nivel 4: Sí; privilegio-menos por defecto; escalation temporal; integración threat intel
- Nivel 5: Sí; zero-standing privilege; continuous justification; behavior analytics

## MÓDULO 5: CAPACITACIÓN Y CONCIENCIA DE SEGURIDAD

### Sección 5A: Programa de Capacitación Formal

**Pregunta 5.1:** ¿Qué tipo de capacitación en ciberseguridad se ofrece? (Seleccionar todos)\*\*

- ☐ Capacitación general de conciencia (awareness) anual
- ☐ Capacitación role-based (desarrolladores, administradores, etc.)
- ☐ Phishing simulation campaigns
- ☐ Capacitación específica herramientas/plataformas
- ☐ Capacitación incident response / crisis management
- ☐ Capacitación suppliers/partners
- ☐ Red team training (ofensiva)
- ☐ Ninguna formal (esperanza es estrategia)

### **Interpretación (# de modalidades):**

- Nivel 0: Ninguna
- Nivel 1: 1
- Nivel 2: 2
- Nivel 3: 3-4
- Nivel 4: 5-6
- Nivel 5: 7-8

### **Pregunta 5.2: ¿Con qué frecuencia se requiere capacitación de conciencia de ciberseguridad?**

- Nivel 0: Nunca (nadie ha notado)
- Nivel 1: Una vez en la vida (onboarding)
- Nivel 2: Anualmente
- Nivel 3: Semestralmente
- Nivel 4: Trimestralmente + adaptive basada performance
- Nivel 5: Continuamente + personalized por role/risk profile

### **Pregunta 5.3: ¿Cuál es el porcentaje de empleados que completó capacitación requerida en el último año?**

- Nivel 0: <25% (participación voluntaria = casi nadie)
- Nivel 1: 25-50% (esfuerzo parcial)
- Nivel 2: 50-75% (cumplimiento incrementando)
- Nivel 3: 75-90% (mayoría cumplidor)
- Nivel 4: 90-98% (obligatoriedad funciona)
- Nivel 5: >98% (cumplimiento universal)

### **Sección 5B: Efectividad de Capacitación y Conciencia**

#### **Pregunta 5.4: ¿Se miden resultados de capacitación más allá de "completó sí/no"?**

- Nivel 0: No; no se mide
- Nivel 1: Sí; test post-training básico; pass/fail
- Nivel 2: Sí; test scores; feedback encuesta
- Nivel 3: Sí; phishing simulation click-rate; reporting rate
- Nivel 4: Sí; phishing reporting time-to-report; behavioral change metrics
- Nivel 5: Sí; resilience ratio; real-threat reporting coverage; quantified incident reduction

**Pregunta 5.5:** ¿Cuál es el resultado estimado de phishing simulations? (e.g., "% de empleados que clickeó")\*\*

- Nivel 0: Sin datos (nunca se simuló)
- Nivel 1: >40% click-rate (preocupante)
- Nivel 2: 25-40% click-rate (room for improvement)
- Nivel 3: 15-25% click-rate (mejorando)
- Nivel 4: 5-15% click-rate (competente)
- Nivel 5: <5% click-rate + >70% reporting rate (resiliente)

**Pregunta 5.6:** ¿Se comunican resultados de capacitación a ejecutivos/junta?

- Nivel 0: No
- Nivel 1: Sí; informes anuales básicos
- Nivel 2: Sí; informes trimestrales con métricas
- Nivel 3: Sí; dashboards con KPIs; trending analysis
- Nivel 4: Sí; integrado en board reporting; tied to business outcomes
- Nivel 5: Sí; real-time analytics; predictive risk trending

### Sección 5C: Estrategia de Conciencia y Engagement

**Pregunta 5.7:** ¿Qué enfoques se utilizan para fomentar engagement en ciberseguridad? (Seleccionar todos)\*\*

- ☐ Gamification (puntos, rankings, premios)
- ☐ Reconocimiento/celebration de good behavior
- ☐ Incentivos económicos
- ☐ Competiciones entre departamentos
- ☐ Storytelling / casos reales
- ☐ Líderes empresariales como champions
- ☐ Acceso a recursos/conocimiento especializado
- ☐ Ninguno formal; enforcement solamente

**Pregunta 5.8:** ¿Se abordan específicamente las siguientes áreas en capacitación? (Seleccionar todos)\*\*

- ☐ Reconocimiento phishing / social engineering
- ☐ Uso seguro de contraseñas / MFA
- ☐ Manejo datos sensibles / confidencialidad
- ☐ Reporte de incidentes / suspichas
- ☐ Bring-your-own-device (BYOD) seguridad
- ☐ Uso redes públicas (WiFi) seguro
- ☐ Reconocimiento deepfakes / manipulación multimedia
- ☐ Privacy y compliance (GDPR, etc.)
- ☐ Todos; robusto coverage

### **Interpretación (# de áreas):**

- Nivel 0: 0
- Nivel 1: 1-2
- Nivel 2: 3-4
- Nivel 3: 5-6
- Nivel 4: 7-8
- Nivel 5: 9 (todos)

## **MÓDULO 6: RESPUESTA A INCIDENTES Y CONTINUIDAD**

### **Sección 6A: Capacidad de Respuesta a Incidentes**

**Pregunta 6.1:** ¿Existe un plan formalizado de respuesta a incidentes (IRP)?

- Nivel 0: No existe
- Nivel 1: Sí; borrador o heredado; sin actualización reciente
- Nivel 2: Sí; documentado; roles asignados; sin testing reciente
- Nivel 3: Sí; actualizado anualmente; roles/responsabilidades claras; testing semestral
- Nivel 4: Sí; versionado; métricas SLA; tabletop exercises regulares
- Nivel 5: Sí; dinámico; integrado en governance; continuous simulation

**Pregunta 6.2:** ¿Se realiza testing/simulación del plan de respuesta a incidentes?

- Nivel 0: No
- Nivel 1: Sí; una vez (ad-hoc)
- Nivel 2: Sí; anualmente
- Nivel 3: Sí; semestralmente (tabletop o funcional)
- Nivel 4: Sí; trimestralmente; full-scale exercises
- Nivel 5: Sí; continuamente; integrated red team simulations

**Pregunta 6.3:** ¿Se documentan lecciones aprendidas post-incidentes?

- Nivel 0: No
- Nivel 1: Sí; informalmente
- Nivel 2: Sí; formalmente en reportes post-incident
- Nivel 3: Sí; documentadas; revisadas por leadership
- Nivel 4: Sí; integradas en updates IRP; trending analysis
- Nivel 5: Sí; closed-loop feedback; automated improvements

### Sección 6B: Métricas de Incidentes

**Pregunta 6.4:** ¿Cuál es el Mean Time to Detect (MTTD) estimado para incidentes?

- Nivel 0: Unknown (>6 meses típico)
- Nivel 1: >180 días (amplio opportunity window para atacantes)
- Nivel 2: 30-180 días
- Nivel 3: 7-30 días
- Nivel 4: 24-72 horas
- Nivel 5: <24 horas

**Pregunta 6.5:** ¿Cuál es el Mean Time to Respond (MTTR) estimado?

- Nivel 0: Unknown (no se mide)
- Nivel 1: >72 horas (lento)
- Nivel 2: 24-72 horas
- Nivel 3: 8-24 horas
- Nivel 4: 2-8 horas
- Nivel 5: <2 horas (automatización asistida)

## MÓDULO 7: ANÁLISIS DE MADUREZ GENERAL

### Sección 7A: Integración Estratégica

**Pregunta 7.1:** ¿En qué medida están integradas las funciones de ciberseguridad con procesos de negocio clave?

- Nivel 0: Silo completo; ciberseguridad = "IT requirement"
- Nivel 1: Mínima integración; awareness solamente
- Nivel 2: Integración parcial; colaboración en proyectos específicos
- Nivel 3: Integración formal; participación en decisiones estratégicas
- Nivel 4: Integración profunda; ciberseguridad integrada en diseño producto/servicio
- Nivel 5: Alineación total; ciberseguridad es valor diferenciador competitivo

**Pregunta 7.2:** ¿Se realiza análisis formal de riesgos cibernéticos para nueva tecnología/vendor?

- Nivel 0: No
- Nivel 1: Sí; review ocasional
- Nivel 2: Sí; checklist básico
- Nivel 3: Sí; framework formal; due diligence documentada
- Nivel 4: Sí; assessment cuantitativo; vendor risk scoring
- Nivel 5: Sí; continuous risk monitoring; integrado en governance procurements

### Sección 7B: Madurez General Percibida

**Pregunta 7.3:** En escala 1-10, ¿cómo calificaría la madurez general de ciberseguridad de la organización?

*Escala Likert 1-10*

**Pregunta 7.4:** ¿Cuáles son los tres mayores gaps identificados? (Texto libre; máx 500 caracteres cada uno)

1.

2.

3.

**Pregunta 7.5:** ¿Cuáles son las tres prioridades clave para próximos 12 meses? (Texto libre; máx 500 caracteres cada uno)

4.

5.

6.

## SECCIONES DE VALIDACIÓN Y CONTROL DE CALIDAD

### Validación Interna Consistencia

**Pregunta Validación 1:** Si respondió "Nivel 3+" en SIEM integration pero "Nivel 0-1" en Threat Hunting, ¿puede explicar?

- ☐ Sí, explicación válida
- ☐ Reconozco inconsistencia; requiere revisión

**Pregunta Validación 2:** Si respondió MFA en "Todos los accesos" pero presupuesto ciberseguridad <3% IT, ¿impacto presupuestario existe?

- ☐ Implementación parcial confirmada
- ☐ Presupuesto debe aumentarse

## **FIN DEL CUESTIONARIO**

**Tiempo Total Estimado:** 50-60 minutos

**Próximos Pasos:** Remitir a análisis profesional según guía metodológica